

Web Güvenliği Saldırıları ve Savunma Mekanizmaları: Kapsamlı Bir Değerlendirme

Yönetici Özeti

Bu belge, modern web uygulamalarına yönelik temel saldırı vektörlerini ve bunlara karşı koymak için kullanılan savunma stratejilerini kapsamlı bir şekilde analiz etmektedir. Web teknolojilerinin masaüstü uygulamalarından web tabanlı hizmetlere doğru evrimi, saldırı yüzeyini önemli ölçüde genişletmiş ve web uygulamalarını saldırganlar için birincil hedef haline getirmiştir. Saldırıları temel olarak iki ana kategoriye ayrılmaktadır: kullanıcı davranışlarını ve cihazlarını hedef alan **istemci taraflı saldırılar** ve sunucu, kod veya arka uç sistemlerindeki zafiyetleri istismar eden **sunucu taraflı saldırılar**. İstemci taraflı saldırıların tespiti, sunucu tarafı araçların tarayıcı içindeki faaliyetlere dair sınırlı görünürlüğü nedeniyle zordur. Buna karşın, sunucu taraflı saldırılar genellikle sunucu günlüklerinde ve ağ trafiğinde izler bırakır. Belge ayrıca, hizmetleri erişilemez kılmayı amaçlayan **Dağıtık Hizmet Engelleme (DDoS)** saldırılarını ve saldırganlara uzaktan komut çalıştırma yetkisi veren **Web Shell** 'leri de ayrıntılı olarak ele almaktadır. DDoS saldırıları, /login veya arama formları gibi kaynak yoğun uç noktaları hedef alırken; Web Shell'ler, dosya yükleme zafiyetleri aracılığıyla hem ilk erişim hem de kalıcılık sağlamak için kullanılır. Savunma stratejileri, web hizmetini oluşturan üç temel bileşene odaklanan katmanlı bir yaklaşımı vurgulamaktadır: **Uygulama**, **Web Sunucusu** ve **Ana Makine**. Etkili savunma yöntemleri arasında güvenli kodlama pratikleri, girdi doğrulama, Web Uygulama Güvenlik Duvarları (WAF), İçerik Dağıtım Ağları (CDN), yama yönetimi ve en az yetki ilkesi bulunmaktadır. Özellikle WAF'lar, şüpheli trafiği filtrelemede ve CAPTCHA gibi meydan okuma mekanizmalarıyla bot trafiğini engellemede kritik bir rol oynarken, CDN'ler DDoS saldırılarının yükünü dağıtarak hafifletir.

Web Servislerinin Evrimi ve Güvenlik Zorlukları

1990'larda masaüstü uygulamalarının standart olduğu dönemden günümüze, teknoloji web tabanlı uygulamalara doğru kaymıştır. 2010'lardaki bulut bilişim ve Hizmet Olarak Yazılım (SaaS) patlamasıyla birlikte, günümüzde neredeyse her işlem bir tarayıcı üzerinden gerçekleştirilebilmektedir. Bu dönüşüm; erişilebilirlik, daha hızlı güncellemeler ve daha iyi uyumluluk gibi önemli avantajlar sunsa da, güvenlik açısından ciddi riskleri de beraberinde getirmiştir. Web uygulamaları sürekli erişilebilir ve dış dünyaya açık olmaları nedeniyle saldırganlar için en yaygın giriş noktalarından biri haline gelmiştir. Genellikle veritabanları gibi arka uç sistemlere bağlı olduklarından, başarılı bir saldırı büyük etkilere yol açabilir ve genellikle daha büyük bir saldırı dizisinin ilk aşamasını oluşturur.

Bir Web Servisinin Bileşenleri

Herhangi bir web hizmetinin çalışması için üç ana bileşen gereklidir:

1. **Uygulama:** Web sitesinin görünümünü ve işlevselliğini belirleyen kod, görseller, stiller ve ikonlar.
2. **Web Sunucusu:** Uygulamayı barındıran, istekleri dinleyen ve kullanıcıya bir yanıt döndüren bileşen.
3. **Ana Makine:** Web sunucusunu ve uygulamayı çalıştıran temel işletim sistemi (Linux veya Windows).

Web Saldırı Vektörleri

İstemci Taraflı Saldırıları

İstemci taraflı saldırılar, kullanıcı davranışındaki veya kullanıcının cihazındaki zayıflıkları kötüye kullanmaya dayanır. Bu saldırılar, genellikle tarayıcılardaki güvenlik açıklarından yararlanarak veya kullanıcıyı güvenli olmayan eylemler gerçekleştirmesi için kandırarak hesaplara erişim sağlamayı ve hassas bilgileri çalmayı hedefler. Dinamik web uygulamalarına yönelik artan talep, şirketlerin daha fazla üçüncü taraf eklentisi entegre etmesine neden olmakta, bu da tarayıcılardaki saldırı yüzeyini genişletmektedir.

SOC Sınırlamaları

Bir Güvenlik Operasyon Merkezi (SOC) analistinin elindeki sunucu tarafı günlükler ve ağ trafiği yakalamaları gibi araçlar, kullanıcının tarayıcısında neler olduğuna dair çok az görünürlük sunar veya hiç sunmaz. İstemci taraflı saldırılar kullanıcının sisteminde gerçekleştiği için, SOC'un görebileceği şüpheli HTTP istekleri veya ağ trafiği oluşturmadan kötü amaçlı kod çalıştırabilir, bilgi çalabilir veya ortamı manipüle edebilirler. Sonuç olarak, bu saldırıları ek tarayıcı tarafı güvenlik kontrolleri veya uç nokta izlemesi olmadan tespit etmek genellikle zordur.

Sunucu Taraflı Saldırıları

Sunucu taraflı saldırılar, bir web sunucusundaki, uygulamanın kodundaki veya bir web sitesini destekleyen arka uçtaki güvenlik açıklarını istismar etmeye odaklanır. İstemci taraflı saldırılar kullanıcıların bir siteyle etkileşimini manipüle ederken, sunucu taraflı saldırılar sistemlerin kendisinden faydalanmayı hedefler. Hataları, güvenlik açıklarını, sunucu mantığını, yanlış yapılandırmaları veya girdi işlemeyi istismar ederek saldırganlar erişim elde edebilir, bilgi çalabilir ve çalışan hizmetlere zarar verebilir.

Sunucu Taraflı Saldırıları Yakalama

Savunmacılar için sunucu taraflı saldırıların bir avantajı, doğru yere bakıldığında bir kanıt izi bırakmalarıdır. Bir uygulamaya gönderilen her web isteği sunucu tarafından işlenir ve günlüklerde veya diğer izleme sistemlerinde kaydedilir. Bu istekler aynı zamanda ağ üzerinden de seyahat eder, bu da ağ trafiğinin şüpheli davranışları ortaya çıkarabileceği anlamına gelir.

Dağıtık Hizmet Engelleme (DDoS) Saldırıları

Özünde, **Hizmet Engelleme (DoS)** saldırıları, bir web sitesini veya uygulamayı aşırı yükleyerek insanların onu kullanamaz hale getirmesini amaçlar. Bu durum, müşterilerin giriş yapmasını, alışveriş yapmasını veya hizmetlere erişmesini engelleyerek işletmelerin para ve güven kaybetmesine neden olur. Saldırıları ölçeklendirmek için saldırganlar, **Dağıtık Hizmet Engelleme (DDoS)** saldırılarına yönelir ve kontrolleri altındaki ele geçirilmiş cihazlardan oluşan bir ordu olan **botnet** 'leri kullanır. Bu botlar, hedeflenen web sitesini veya uygulamasını trafikle boğarak tek bir makinenin yapabileceğinden çok daha etkili bir şekilde aşırı yükler.

Hedef Alınan Kaynaklar

Salırganlar, bir web hizmetini kesintiye uğratmayı hedefliyorsa, istek başına en fazla sunucu kaynağını tüketen veya site işlevselliğini sürdürmek için en kritik olan uç noktalara

odaklanırlar. /login veya arama formları gibi sayfalar, her isteğin sunucuyu bir veritabanını sorgulamaya, girdiyi doğrulamaya ve sonuçları döndürmeye zorlaması nedeniyle birincil hedeflerdir.

- **/login:** Kimlik doğrulama süreçlerini içerir.
- **/search:** Karmaşık veritabanı sorguları gerektirir.
- **/api uç noktaları:** Dinamik içerik dağıtımı için kritiktir.
- **/register veya /signup:** Veritabanına yazma ve doğrulama gerektirir.
- **/cart veya /checkout:** Oturum yönetimi, envanter kontrolü ve ödeme işlemleri gerektirir.

Web Shell'ler

Web shell, hedef bir web sunucusuna yüklenen ve saldırganların uzaktan komut çalıştırmasına olanak tanıyan kötü amaçlı bir programdır. Web shell'ler genellikle hem bir ilk erişim yöntemi (dosya yükleme zafiyetleri yoluyla) hem de bir kalıcılık mekanizması olarak hizmet eder. Bir sunucuya erişim sağlandıktan sonra saldırganlar, keşif yapmak, ayrıcalıkları yükseltmek, yanal hareket etmek ve veri sızdırmak için bir web shell kullanabilir.

Web Shell Dağıtımı

Bir saldırganın bir web shell yükleyip çalıştırabilmesi için bir dosya yükleme zafiyeti, yanlış yapılandırma veya sisteme önceden erişim gereklidir. Bu zafiyetler, bir uygulamanın dosya türünü, uzantısını, içeriğini veya hedefini doğrulamada başarısız olması durumunda ortaya çıkar. Örneğin, evcil hayvan fotoğraflarını yüklemeye izin veren güvenli olmayan bir web sitesi, bir saldırganın shell.php gibi bir web shell yüklemesine ve sunucuda komut çalıştırma yetkisi elde etmesine olanak tanıyabilir.

Saldırı Tespiti ve Analizi

DDoS Göstergeleri

Gösterge,Örnek,Açıklama

Yüksek İstek Oranı,10.10.10.100 → 1000 GET /login,"/login gibi kaynak yoğun bir sayfa, kimlik doğrulama süreçlerini aşırı yüklemek için isteklerle doldurulur."

Garip User-Agent'lar,curl/7.6.88 → /index (tekrar tekrar),"Saldırganlar, filtrelemlere takılmamak veya gizlenmek için güncel olmayan veya sıra dışı User-Agent'lar kullanır. curl gibi araçlardan gelen trafik, otomatik saldırılar için bir işaret olabilir."

Coğrafi Anormallikler,Dünya geneline dağılmış IP adresi kökenleri,"Meşru trafik genellikle gerçek kullanıcıların bulunduğu birkaç bölgeden gelir. Küresel olarak dağıtılmış bir botnet, dünyanın dört bir yanından IP adresleri kullanabilir."

Ani Zaman Damgaları,1 saniyede 50 istek → /search,"Aynı saniye içine sıkıştırılmış ani bir istek artışı, otomasyona işaret eden doğal olmayan bir trafik deseni oluşturur."

Sunucu Hataları (5xx),503 Service Unavailable hatalarında önemli bir artış,"Sunucu hata yanıtlarında (500-511) ani bir artış, kaynakların tükendiğini ve hizmetin saldırı trafiği altında zorlandığını gösterir."

Mantık İstismarı,GET /products?limit=999999,"Saldırganlar, sunucuyu aşırı yükleyen ve çok büyük miktarda bilgi yüklemeye zorlayan sorgular oluşturur."

Web Shell Tespiti

Web Sunucusu Günlükleri

Web shell'ler web sunucularının kötüye kullanılmasına dayandığından, web sunucusu günlükleri kanıt aramak için doğal bir başlangıç noktasıdır. **Erişim günlükleri** genellikle şu bilgileri içerir: istemci IP adresi, istek zaman damgası, HTTP metodu, istenen kaynak, HTTP durum kodu ve User-Agent. remote log name ve authenticated user alanları genellikle eski ve nadiren kullanıldığı için tire (-) ile temsil edilir.

Dosya Sistemi Analizi

Bir saldırganın web shell'i bir yerde saklanmalıdır. Web sunucusu dosyalarını analiz etmek, yüklenmiş web shell'leri belirlemek veya bir web shell yükü içerecek şekilde değiştirilmiş dosyaları bulmak için hayati önem taşır. Ancak WordPress ve Django gibi bazı platformların sayfa içeriğini bir dosya sisteminden ziyade bir veritabanında sakladığı unutulmamalıdır, bu nedenle kötü amaçlı kod normal dosya sistemi aramalarında görünmeyebilir.

Ağ Trafiği Analizi

Ağ trafiği analizi, bir istemci ile sunucu arasında değiş tokuş edilen verileri inceleyerek analistlerin günlüklerin ötesine geçmesini sağlar. Paket yüklerini inceleyerek saldırgan davranışını daha ayrıntılı bir düzeyde gözlemlemek mümkündür. Günlük analizinde aranan göstergelerin birçoğu ağ trafiği analizine de uygulanabilir:

- Olağandışı HTTP Metotları ve İstek Desenleri
- Şüpheli User-Agent'lar ve IP Adresleri
- Kodlanmış Yükler
- İstek Gövdelerinde Kötü Amaçlı Kod veya Komutlar
- Web Sunucusu Süreçlerinin Komut Satırı Araçlarını Başlatması

Auditd

auditd, olayları izleyen ve kaydeden, bir denetim izi oluşturan yerel bir Linux yardımcı programıdır. Belirli koşullara uyan kurallar oluşturularak, belirli programlar çalıştırıldığında veya dosyalar değiştirildiğinde neyin günlüğe kaydedileceği belirlenebilir. Örneğin, ausearch -k web_shell komutu, web_shell kuralıyla eşleşen günlükleri aramak için kullanılabilir.

Savunma Stratejileri ve En İyi Uygulamalar

Katmanlı Savunma Yaklaşımı

Web hizmetlerinin üç temel bileşeni olan uygulama, web sunucusu ve ana makine için çeşitli güvenlik önlemleri mevcuttur. **Uygulamayı Koruma:**

- **Güvenli Kodlama:** Güvensiz fonksiyonlardan kaçının, hataların doğru şekilde ele alındığından emin olun ve hassas bilgileri kaldırın.
- **Girdi Doğrulama ve Temizleme:** Enjeksiyon saldırılarını önlemek için kullanıcı girdisini doğrulayın ve temizleyin.
- **Erişim Kontrolü:** Kullanıcı rollerine göre erişimi kısıtlayın. **Web Sunucusunu Koruma:**
- **Günlükleme:** Tüm web isteklerinin ayrıntılı bir kaydını tutun.
- **Web Uygulama Güvenlik Duvarı (WAF):** Tanımlanmış kurallara göre zararlı trafiği filtreleyin ve engelleyin.

- **İçerik Dağıtım Ağı (CDN):** Sunucunuza doğrudan maruz kalmayı azaltın ve entegre WAF'ları kullanın.**Ana Makineyi Koruma:**
- **En Az Yetki İlkesi:** Hizmetler için düşük ayrıcalıklı kullanıcılar kullanın.
- **Sistem Sıkılaştırma:** Gereksiz hizmetleri devre dışı bırakın ve kullanılmayan portları kapatın.
- **Antivirüs:** Bilinen kötü amaçlı yazılımları engelleyen uç nokta düzeyinde koruma ekleyin.**Tüm Bileşenler İçin Güvenlik İpuçları:**
- **Güçlü Kimlik Doğrulama:** Kodunuza, yönetici panellerinize veya ana makinenize herkesin erişmesine izin vermeyin.
- **Yama Yönetimi:** Uygulama bağımlılıklarınızın, web sunucunuzun ve ana makinenizin güncel olduğundan emin olun.

Önemli Savunma Teknolojileri

Web Uygulama Güvenlik Duvarı (WAF)

WAF'lar, gelen HTTP trafiğini inceleyen ve güvenlik kurallarına göre potansiyel olarak zararlı istekleri engelleyen veya günlüğe kaydeden güçlü bir araçtır. Farklı türleri mevcuttur:

- **Bulut tabanlı (Ters Proxy):** Dağıtımı kolaydır ve mükemmel ölçeklenebilirlik sunar.
- **Ana makine tabanlı:** Doğrudan web sunucusuna dağıtılan ve her uygulama için kontrol sunan yazılım.
- **Ağ tabanlı:** Ağ çevresine yerleştirilen fiziksel veya sanal bir cihaz.WAF'lar, şüpheli istekleri doğrudan engellemek yerine **CAPTCHA** gibi meydan okumalarla sorgulayarak isteğin gerçek bir kullanıcıdan mı yoksa bir bottan mı geldiğini doğrulayabilir. Bu, küresel web trafiğinin %37'sini oluşturan kötü amaçlı bot trafiği göz önüne alındığında son derece değerli bir yetenektir.

İçerik Dağıtım Ağı (CDN)

CDN'ler, içeriği kullanıcılara en yakın uç sunuculardan önbelleğe alıp sunarak sunucu yükünü yönetmeye yardımcı olur. Bu, gecikmeyi azaltır ve kaynak sunucunun yalnızca isteklerin bir kısmını işlemlerini sağlarken, CDN çoğunluğu sunar. Sonuç olarak, CDN'ler DDoS saldırılarını hafifletme yükünün büyük bir kısmını üstlenir. Ayrıca, trafiği sunucular arasında dağıtmak için yük dengeleme sağlarlar.

Uygulama Seviyesi DDoS Savunmaları

- **Güvenli Geliştirme Pratikleri:** Güvenli bir site, güvenli kodla başlar. Arama alanları ve formlar, kötüye kullanılmamaları için girdiyi doğrulamalıdır. Bu, "sadece 50 karakter altındaki başlıkları ara" gibi net kuralları olan bir kütüphaneciye benzetilebilir; kurallar olmadan, birisi kütüphaneciden aşırı uzun bir başlık aramasını isteyerek onu yavaşlatabilir.
- **Meydan Okumalar (Challenges):** Otomatik trafiği durdurmanın bir yolu, erişim izni vermeden önce bir meydan okuma gerektirmektir. Bu, bir kullanıcının bir bulmacayı çözdüğü bir **CAPTCHA** olabilir. Ayrıca, bir ziyaretçinin gerçek bir kullanıcı mı yoksa otomatik trafik mi olduğunu doğrulamak için arka planda sessizce çalışan **JavaScript meydan okumaları** da kullanılabilir. Bu meydan okumalar, botnet'lere karşı etkili bir filtre görevi görür.